

Use cases of SBOMs: Theory

Landscape Study of Open Source and Proprietary Tools for Software Bill of Materials (SBOM)

Notable SBOM tool use cases:

1. **SBOM generation**
2. **SBOM consumption:** Utilisation of SBOMs for supply chain security after generation
3. **SBOM quality assurance**
4. **SBOM services:** Facilitating exchange of SBOM artifacts. E.g: incident response

SBOM Challenges for Developers: From Analysis of Stack Overflow Questions

Notable analysis:

1. Insufficient coverage of use cases by SBOM tools
2. **Inability of SBOM tools to meet requirements**
3. Immaturity of SBOM tools or unclear usages

Use cases of SBOMs: Implementation

Implementing a use case and finding vulnerabilities



SBOM generation:

Not all dependencies are necessarily reflected in the SBOM tools

SBOM consumption:

Time lapse between discovery of vulnerability and it being populated in the database

Vulnerability spreading:

Time lapse between vulnerability being populated in the database and the notification pushed to software vendors

SBOM Consumption: Vulnerability Exploitability eXchange

Workflow:

- Generate SBOM
- Import SBOM into the VEX generation tool and it should automatically scan for known vulnerabilities using some database.
- The VEX generation tool can fetch public VEX documents if they have been uploaded by upstream vendors or users can provide VEX documents directly for the tool to ingest from a vendor or users can manually annotate the vulnerabilities and generate a VEX document themselves.
- The VEX entries update users view of an SBOM by showing all risks. It gives you an enriched version of the SBOM with vulnerability data, VEX context and risk classifications to view.

```
{
  "vulnerabilities": [
    {
      "id": "CVE-2018-7489",
      "source": {
        "name": "NVD",
        "url": "https://nvd.nist.gov/vuln/detail/CVE-2019-9997"
      },
      "analysis": {
        "state": "not_affected",
        "justification": "code_not_reachable",
        "response": [
          "will_not_fix",
          "update"
        ],
        "detail": "An optional explanation of why the application is not affected by the vulnerable component."
      },
      "affects": [
        {
          "ref": "urn:cdx:3e671687-395b-41f5-a30f-a58921a69b79/1#jackson-databind-2.8.0"
        }
      ]
    }
  ]
}
```

Proposal

We propose a followup paper to the minimum elements paper, where we outline a theoretical framework for the generation of SBOMs

The framework can focus on providing:

- A minimum guarantee for the type of dependencies used being captured by the SBOM
- Its limitations in the type of dependencies not captured by this SBOM
- Minimising the limitations
- An implementation strategy for its use
- Explore what is hindering usage

Implementation strategies:

1. An analysis of SBOM scoring tools and finding metrics to form the basis of requirements of our framework
2. An analysis of open source SBOM generation tools which fulfil these requirements
3. Comparative analysis between these tools to point out the minimum steps through which this can be provided